

RED TEAM ENGAGEMENT REPORT

OPERACIÓN GHOST FOREST — Lab-01

CAMPO	DETALLE
Nombre de operación	GHOST FOREST
Clasificación	CONFIDENCIAL — Solo uso educativo
Adversario emulado	APT29 (Cozy Bear) — Servicio de Inteligencia Exterior de Rusia (SVR)
Objetivo primario	Domain Admin sobre attackcorp.local
Objetivo secundario	DCSync — Volcado completo de hashes del dominio
Entorno	Lab propio — VirtualBox NAT Network LabRedTeam (10.0.2.0/24)
Período	09/05/2026 — 20/05/2026
Operador	Adrián Camacho
Framework	MITRE ATT&CK v14 — Enterprise

1. RESUMEN EJECUTIVO

La operación GHOST FOREST es una emulación completa de APT29 (Cozy Bear) contra el dominio attackcorp.local. En el transcurso de 13 fases se comprometió completamente el dominio, obteniendo acceso como Domain Administrator y volcando todos los hashes de contraseñas. Se identificaron y explotaron múltiples vulnerabilidades críticas de configuración en Active Directory, incluyendo configuraciones inseguras de Kerberos, delegaciones mal configuradas, abuso de GPOs y permisos ACL incorrectos.

El dominio fue comprometido en su totalidad. Se obtuvieron hashes NT de todas las cuentas incluyendo krbtgt, lo que permite persistencia indefinida mediante Golden/Diamond Tickets. El tiempo total de operación fue aproximadamente 40 horas distribuidas en múltiples sesiones.

2. ALCANCE Y ENTORNO

HOST	IP	SO	ROL
DC-01	10.0.2.10	Windows Server 2022	Domain Controller — Objetivo primario
WKSTN-01	10.0.2.8	Windows 11 Enterprise	Workstation — Objetivo secundario
Kali	10.0.2.9	Kali Linux 2026.1	Máquina operadora

3. KILL CHAIN — RESUMEN

FASE	TÉCNICA	RESULTADO	MITRE
1 — Recon	Network scan + LDAP enum	Usuarios y servicios mapeados	T1046, T1087
2 — Credential Access	AS-REP Roasting	backup_svc: Backup2024! crackeada	T1558.004
2 — Credential Access	Kerberoasting	sql_svc: SQLService2024! crackeada	T1558.003

3 — Initial Access	Evil-WinRM	Shell como ceo.martinez en DC-01	T1021.006
4 — Discovery	BloodHound CE + SharpHound	Attack paths completos mapeados	T1087.002
5 — Cred. Access	MSSQL xp_cmdshell	Ejecución de comandos via SQL	T1505
6 — Lateral Mov.	Pass-the-Hash	Shell en WKSTN-01	T1550.002
7 — C2	Sliver beacon	Sesión C2 activa desde WKSTN-01	T1071.001
8 — Priv. Esc.	Token Impersonation	SYSTEM en WKSTN-01 (parcial)	T1134.001
9 — Persistence	Golden Ticket	Bloqueado por PAC Validation WS2022	T1558.001
10 — Objective	DCSync	Todos los hashes del dominio obtenidos	T1003.006
11 — Delegation	Unconstrained + Constrained	TGT DC-01\$ capturado + S4U2Proxy	T1558.001
12 — GPO Abuse	SYSVOL + ScheduledTask	helpdesk.ruiz → Admin local WKSTN-01	T1484.001
13 — ACL Abuse	GenericWrite → Kerberoast	sql_svc: SQLService2024! via Targeted KRB	T1558.003

Cuenta	Contraseña / Hash NT	Método	Privilegio
backup_svc	Backup2024!	AS-REP Roasting	Member of Domain Admins
sql_svc	SQLService2024!	Kerberoasting + Targeted KR (J13)	Unconstrained Delegation
ceo.martinez	Direccion2024!	AS-REP Roasting	Usuario de dominio
iis_svc	IISService2024!	Reset + Constrained Delegation (F11)	Constrained Delegation
helpdesk.ruiz	Helpdesk2024!	GPO Abuse → Admin local WKSTN-01	Admin local WKSTN-01
fin.garcia	Finance2024!	Credential hunting	GenericWrite sobre sql_svc
Administrador	bc3abc2e0673a58e9e559d415b56b940c5940c	NTLM (NT)	Domain Admin
krbtgt	d5237a2e43cb315c90679e2a5daeb2849c	NTLM (NT)	Cuenta crítica — Golden Ticket

ID	DESCRIPCIÓN	CVSS	TÉCNICA MITRE
V-01	AS-REP Roasting — backup_svc y ceo.martinez sin pre-auth Kerberos	7.5 High	T1558.004
V-02	Kerberoasting — sql_svc con SPN y contraseña débil pre-auth	7.5 High	T1558.003
V-03	Unconstrained Delegation — sql_svc con TrustedForDelegation=True	9.0 Critical	T1558.001
V-04	Constrained Delegation insegura — iis_svc con S4U2Self y sin restricción	7.5 High	T1558.001
V-05	GPO Abuse — helpdesk.ruiz con GpoEditDeleteModifySecurty sobre ITF4341001	8.5 High	T1484.001
V-06	ACL Abuse — fin.garcia con GenericWrite (WriteProperties) sobre sql_svc	7.5 High	T1222
V-07	Credenciales débiles en cuentas de servicio (patrón NombreServicio+Admin)	7.0 High	T1111.0.002
V-08	MSSQL xp_cmdshell habilitado — ejecución de comandos via SQL	6.0 High	T1505

6. RECOMENDACIONES

PRIORIDAD	RECOMENDACIÓN	VULNERABILIDAD
CRÍTICA	Habilitar pre-autenticación Kerberos en todas las cuentas	V-01
CRÍTICA	Eliminar TrustedForDelegation de sql_svc — usar gMSA	V-03
ALTA	Rotar contraseñas de todas las cuentas de servicio a +25 chars aleatorios	V-02, V-07
ALTA	Revisar y restringir permisos GPO — helpdesk.ruiz no debe tener GpoEditDeleteModifySecurity	V-05
ALTA	Auditar y remediar ACLs de AD — fin.garcia no debe tener GenericWrite solo en cuentas de servicio	V-06
ALTA	Migrar cuentas de servicio a gMSA (Group Managed Service Accounts)	V-02, V-03, V-07
MEDIA	Deshabilitar xp_cmdshell en todas las instancias SQL	V-08
MEDIA	Implementar Tier Model — separar cuentas Tier 0/1/2	General
MEDIA	Habilitar Protected Users Security Group para cuentas privilegiadas	V-01, V-03
MEDIA	Desplegar Defender for Identity (MDI) para detección de ataques Kerberos	General